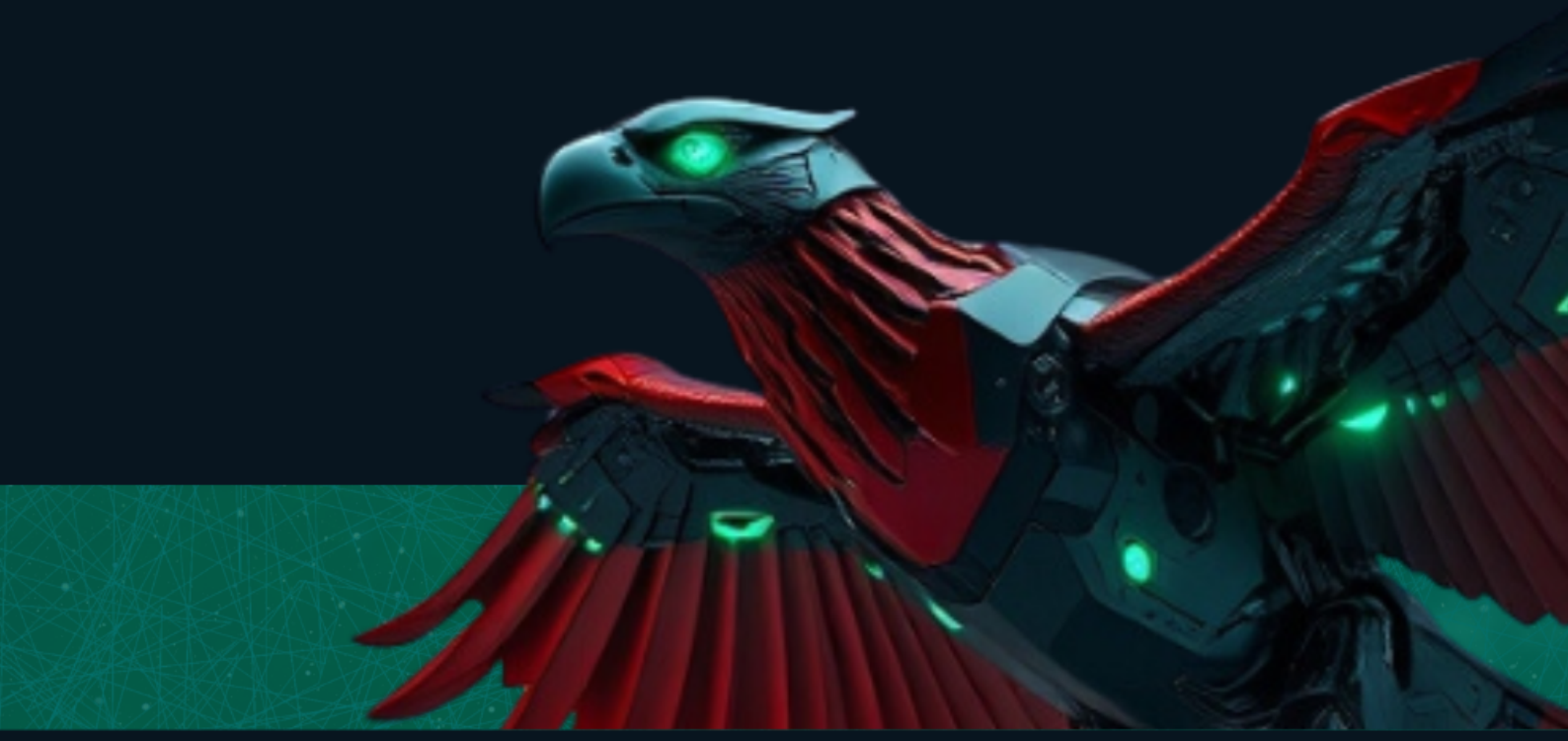
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	Threat Hunt Sly Spider
Sub Title	Financially motivated eCrime threat actor
Status	Closed
Type	Alert
Severity	High
Source	Multiple Sources
Created At	Sep 08, 2026, 08:35 PM

Threat Hunt Sly Spider

Financially motivated eCrime threat actor

Type: ALERT • Source: Multiple Sources • Created At: Sep 08, 2026, 08:35 PM

Analysis Summary

Summary:

On 09/08/2026 at 7:30 PM, Cythority's vSOC conducted a threat hunt focused on Sly Spider covering activity within the past 30 days. Sly Spider is a financially motivated eCrime threat actor best known as the developer and primary operator of the Gozi ISFB banking trojan, which it offers on underground cybercrime forums as a Malware-as-a-Service (MaaS) platform. Over time, the adversary expanded its criminal infrastructure by partnering with other eCrime groups, such as Smoky Spider and Apothecary Spider, and aligning with ransomware operations like WhiteRabbit and RansomHouse. Their custom malware ecosystem primarily facilitates financial fraud, credential harvesting, and initial environment access for downstream affiliate attacks, making them a key facilitator in the cybercriminal landscape.

During this hunt, a total of 20 Indicators of Compromise (IOCs) were identified, including domains, URLs, IP addresses, and file hash values. These indicators were aggregated from internal telemetry, and additional intelligence sources referenced in this report. All identified IOCs were enriched using OSINT and threat intelligence platforms to validate their reputation. Analysis confirmed that the indicators are associated with malicious activity.

A CQL Advanced Event Search was conducted across the environment to identify any evidence of activity related to these indicators. No matches or suspicious activity were observed, confirming no current or historical presence within the environment. As a preventative measure, the validated malicious IOCs have been added to the IOC Management Block List to mitigate potential future exposure. This proactive control strengthens the security posture and reduces the attack surface. Based on the investigation and analysis performed, no impact to the environment has been identified and no further action is required at this time.

Targeted Industries:

Extractive, Government, Technology, Retail, Legal, Automotive, Utilities, Consumer Goods, Local Government, Aviation, Academic, Telecommunications, Industrials and Engineering, Law Enforcement, Real Estate, Transportation, NGO, Emergency Services, Manufacturing, Logistics, Opportunistic, Hospitality, Financial Services, Agriculture, Media, Healthcare, Energy, Aerospace, Food and Beverage, Chemicals.

Targeted Countries:

Monaco, China, Canada, Czech Republic, Hong Kong, Malaysia, Sweden, Switzerland, Italy, South Africa, Belgium, Colombia, Pakistan, Indonesia, Finland, Denmark, Maldives, Spain, Taiwan, Uruguay, Greece, Netherlands, United States, Paraguay, United Arab Emirates, Bulgaria, Germany, Australia, Vanuatu, Thailand, Saudi Arabia, France, Austria, Japan, United Kingdom, Brazil, Philippines, Singapore, Portugal, Dominican Republic, India, Romania, Malta, Puerto Rico**.**

Community Identifiers:

Gozi ISFB, ISFB, Ursnif, Papras, Pandemyia, DreamBot

Affected Product

- Gozi ISFB
- Ursnif
- WhiteRabbit
- RansomHouse
- Mario Encryptor
- Microsoft Windows
- Linux
- VMware ESXi
- Active Directory
- Domain Controllers
- File Servers
- Network Shares
- Web Browsers
- Online-Banking Applications
- Email Systems
- Remote-Access Services
- Backup Systems
- Cobalt Strike

Impact

- File encryption
- Backup deletion
- Stopped services
- Internal Defacement
- Data-leak-site publication
- Integrity loss
- record alteration.
- Credential Theft
- Banking Fraud

- Financial Data Theft
- Account Takeover
- Keylogging
- Web Injection
- Session Hijacking
- Cookie Theft
- Password Theft
- Data Exfiltration
- Unauthorized Access
- Lateral Movement
- Malware Deployment
- Ransomware Encryption
- Business Disruption

Indicators of Compromise (IOCs)

MD5 Hashes

- 8e29fa5f88ea28e36893f0b82b4d75e3
- 5afedfdd57b7ea0c03977a10f64fd2f4
- c6a85b251c197cbe25603468c8df9392
- 127d91b5a6b945bf7f4111745d786e1a
- 58169007c2e7a0d022bc383f9b9476fe

SHA256 Hashes

- 57befac41319e7e1fc9d6cd5637240fa766bdbc562d7720bb04beee36113ae10
- C59dc482b521b021813681f99a8570aa0f57a30bcf42d48667eb09ae635cc9a1
- 52cb2bd9724270b3efe575894112d0a866734856a3257ddcfb24308e42861f6a
- F2556099982b2b1ebea7443c863b8b205b6683112624f46393454e430e69aed5
- C486d8579308999b7d9f8cbb6de33b7a3976b9db5b98c06b7744adf5d5d11caf
- c2ee9cf24f0bddb07914503dbae35c4497d66f9ca01ea65108ef40ff13cbec02

IP

- 134[.]0[.]118[.]203
- 62[.]173[.]138[.]28
- 94[.]198[.]54[.]97
- 91[.]241[.]93[.]111
- 87[.]106[.]18[.]141

DOMAIN

- iujdhsndjfks[.]ru
- reggy505[.]ru
- apr.intoolkom[.]at
- gameindikdowd[.]ru

Remediation

• **Harden Email Security & Disable Macros:** Block suspicious inbound attachments (e.g., zipped JS, ISO, or macro-enabled Office files) and enforce strict macro policies (or disable VBA macros entirely) across the organization to neutralize their primary initial access vector

- **Implement Multi-Factor Authentication (MFA) & FIDO2 Keys:** Enforce robust, phishing-resistant MFA (such as hardware security keys) across all external-facing portals, VPNs, and cloud environments to prevent stolen web-injected credentials or session cookies from granting unauthorized access
- **Deploy Endpoint Detection & Response (EDR):** Utilize advanced EDR solutions configured to monitor and detect key Gozi ISFB execution behaviors, such as process hollowing, thread local storage injection into system processes, and malicious registry autostart modifications
- **Network Traffic Filtering & DGA Monitoring:** Implement DNS filtering and anomaly-based network monitoring to inspect HTTP/HTTPS POST requests for rare hostnames or dynamic Domain Generation Algorithms (DGA) used by Gozi C2 servers
- **Restrict Administrative Access & Enforce Least Privilege:** Limit local administrative privileges and restrict tools like PowerShell or WMI to reduce the capability of downstream affiliates attempting to deploy secondary payloads or ransomware
- **Conduct Security Awareness & Phishing Training:** Train users to recognize spear-phishing attempts, suspicious web-injection prompts, and unexpected file downloads targeting financial and internal applications
- **Maintain Continuous Offsite Backups & Patching:** Maintain offline, encrypted backups and routinely update operating systems and third-party software to prevent secondary ransomware deployment and exploit kit activity
- **Harden Email Security & Disable Macros:** Block suspicious inbound attachments (e.g., zipped JS, ISO, or macro-enabled Office files) and enforce strict macro policies (or disable VBA macros entirely) across the organization to neutralize their primary initial access vector
- **Implement Multi-Factor Authentication (MFA) & FIDO2 Keys:** Enforce robust, phishing-resistant MFA (such as hardware security keys) across all external-facing portals, VPNs, and cloud environments to prevent stolen web-injected credentials or session cookies from granting unauthorized access

- **Deploy Endpoint Detection & Response (EDR):** Utilize advanced EDR solutions configured to monitor and detect key Gozi ISFB execution behaviors, such as process hollowing, thread local storage injection into system processes, and malicious registry autostart modifications
- **Network Traffic Filtering & DGA Monitoring:** Implement DNS filtering and anomaly-based network monitoring to inspect HTTP/HTTPS POST requests for rare hostnames or dynamic Domain Generation Algorithms (DGA) used by Gozi C2 servers
- **Restrict Administrative Access & Enforce Least Privilege:** Limit local administrative privileges and restrict tools like PowerShell or WMI to reduce the capability of downstream affiliates attempting to deploy secondary payloads or ransomware
- **Conduct Security Awareness & Phishing Training:** Train users to recognize spear-phishing attempts, suspicious web-injection prompts, and unexpected file downloads targeting financial and internal applications
- **Maintain Continuous Offsite Backups & Patching:** Maintain offline, encrypted backups and routinely update operating systems and third-party software to prevent secondary ransomware deployment and exploit kit activity